

Security en AWS — Concept Map SAA-C03

Región base: **eu-west-1** | Restricción: **sin claves estáticas si hay alternativa IAM/role/SSM**

Diagramas generados: [iam-cross-account.png](#) · [kms-encryption-layers.png](#) · [security-observability.png](#) · [edge-protection-layers.png](#) · [organizations-identity-center-control-tower.png](#)

A) Mindmap Jerárquico

SECURITY EN AWS (SAA-C03)

```

|
|— 1. IAM – Identity & Access Management
|   |— Identidades
|   |   |— IAM User      → entidad con credenciales a largo plazo (clave
+secret)
|   |   |
|   |   |   PROBLEMA: claves estáticas → rotar/evitar en
apps
|   |   |— IAM Group    → colección de usuarios, hereda policies del
grupo
|   |   |
|   |   |   NO puede asumir roles; NO puede ser principal
en trust policies
|   |   |— IAM Role     → identidad SIN credenciales permanentes
|   |   |   PARA: EC2, Lambda, ECS tasks, Cross-account,
Federated users
|   |   |
|   |   |   MEJOR PRÁCTICA: siempre role en apps/servicios
|   |   |— Root Account → NUNCA usar para operaciones diarias; MFA
obligatorio
|   |   |
|   |   |— Policies
|   |   |   |— Identity-based → adjunta a User/Group/Role → "qué puede
hacer"
|   |   |       |— Managed AWS → AWS la mantiene (ej: AmazonS3ReadOnlyAccess)
|   |   |       |— Managed Cust → la empresa la mantiene, reutilizable
|   |   |       |— Inline     → 1:1 con la identidad, NO reutilizable →
EVITAR
|   |   |   |— Resource-based → adjunta al recurso (S3 bucket, KMS key, SQS)
|   |   |       → permite cross-account sin AssumeRole (solo
algunos servicios)
|   |   |       EXAMEN: S3 bucket policy, KMS key policy,
SQS queue policy
|   |   |   |— Permission    → establece límite máximo; NO otorga permisos
|   |   |       Boundaries    → "límite de hasta dónde puedes ir"
|   |   |       EXAMEN: delegación segura a devs (no pueden
darse más permisos)
|   |   |   |— SCP (Org.)    → límite para cuentas en AWS Organizations
|   |   |       → se aplica ANTES de evaluar las IAM
policies de la cuenta
|   |   |— Session Policies → límite temporal al asumir un rol (AssumeRole
--policy)
|   |
|

```

- └─ Evaluación de permisos (orden de precedencia)
 1. Explicit DENY → siempre gana, incluso si hay Allow
 2. SCP (Organizations)
 3. Permission Boundary
 4. Identity-based policy
 5. Resource-based policy
 6. Default: DENY implícito
- └─ STS – Security Token Service
 - └─ AssumeRole → obtiene credenciales temp. para un rol
 - └─ AssumeRoleWithWebIdentity → OIDC federation (Cognito, Google...)
 - └─ AssumeRoleWithSAML → SAML 2.0 (AD, Okta...)
 - └─ GetSessionToken → MFA para un IAM User
- └─ Cross-Account Access (ver diagrama iam-cross-account.png)
 - └─ Cuenta A (quien llama): tiene permiso sts:AssumeRole
 - └─ Cuenta B (destino): Role con Trust Policy que permite a Cuenta A
 - └─ Resultado: credenciales temp. con los permisos del rol de Cuenta B
- └─ 2. Autenticación y Acceso a Recursos
 - └─ EC2 – Acceso sin SSH
 - └─ SSM Session Manager → sin llaves, sin puerto 22, sin bastion
 - └─ Requiere: agente SSM + IAM role con AmazonSSMManagedInstanceCore
 - └─ Auditoría: sesiones en CloudTrail + CloudWatch Logs (opcional S3)
 - └─ SSM Run Command → ejecutar en múltiples instancias por tag
 - └─ Port Forwarding → tunneling seguro sin SSH
 - └─ EC2 Instance Connect → credenciales SSH temporales (≠ SSM, aún usa SSH)
 - EXAMEN: SSM >>> Instance Connect para HIPAA/PCI
 - └─ MFA y Conditions en Políticas
 - └─ aws:MultiFactorAuthPresent → true solo si sesión autenticada con MFA
 - └─ aws:RequestedRegion → restringir a eu-west-1 solamente
 - └─ aws:SourceIp → restringir a CIDR corporativo
 - └─ aws:PrincipalTag → ABAC (Attribute-Based Access Control)
 - └─ S3 – Acceso (tres capas)
 - └─ IAM Policy (identity-based)
 - └─ quién puede qué → funciona para usuarios/roles en la MISMA cuenta
 - └─ Bucket Policy (resource-based)
 - └─ permite acceso cross-account sin AssumeRole
 - └─ bloquear acceso público: aws:SecureTransport → deny HTTP
 - └─ limitar a VPC: aws:SourceVpc (con VPC Endpoint)
 - └─ ACLs – LEGACY, EVITAR

- desactivar: Block Public Access settings → disable ACLs
 - EXAMEN: si preguntan ACLs modernas → respuesta = Bucket Policy
- 3. Cifrado y Gestión de Secretos
 - KMS – Key Management Service (ver diagrama kms-encryption-layers.png)
 - CMK (Customer Managed Key)
 - AWS Managed Key → gratis, gestionada por AWS, no configurable
 - ej: aws/s3, aws/rds, aws/ebs
 - Customer Managed → control total, rotación, key policy, auditable
 - EXAMEN: KMS CMK cuando mencionan "control del key"
 - Envelope Encryption → KMS genera DEK (Data Encryption Key)
 - DEK cifra los datos → KMS cifra el DEK → almacena DEK
 - cifrado con datos
 - Qué cifra KMS
 - S3 → SSE-KMS (encabezado x-amz-server-side-encryption)
 - EBS → volumen cifrado en creación (no se puede cifrar existente in-place)
 - RDS/Aurora → storage encryption en creación del cluster
 - DynamoDB → encryption at rest (default AWS managed)
 - Secrets Mgr → cifra el valor del secreto
 - SSM Param → SecureString usa KMS
 - KMS + CloudTrail → TODOS los kms:Decrypt, kms:GenerateDataKey quedan en trail
 - Encryption in Transit (TLS)
 - ACM (Certificate Manager)
 - Certificados gratuitos para ALB, CloudFront, API Gateway
 - Auto-renovación (válido 13 meses, renueva a los 60 días)
 - NO exportable para instalar en EC2 directamente
 - EXAMEN: EC2 con cert propio → usar CA privada o cert externo en ACM
 - TLS 1.2+ obligatorio en todos los servicios modernos AWS
 - Gestión de Secretos
 - Secrets Manager
 - Rotación automática (Lambda) – cada N días
 - Integrado con RDS, Aurora, Redshift, DocumentDB
 - Cross-account (resource-based policy)
 - Coste: ~\$0.40/secreto/mes + \$0.05 / 10.000 API calls
 - CUÁNDO: credenciales DB, API keys, rotación automática
 - SSM Parameter Store
 - Standard (gratis): max 4KB, sin rotación automática nativa
 - Advanced (\$0.05/param/mes): max 8KB, políticas de expiración
 - SecureString = KMS-encrypted
 - CUÁNDO: configuración de app, parámetros no-sensibles o bajo coste

```

|
|— 4. Logging, Auditoría y Postura
|   |— CloudTrail (ver diagrama security-observability.png)
|   |   |— QUÉ registra: API calls (Management Events por defecto)
|   |   |   |— Management Events → crear/modificar recursos (gratis, 1
trail)
|   |   |   |— Data Events → S3 GetObject/PutObject, Lambda invoke
(coste extra)
|   |   |   |— Trail → entrega logs a S3 (immutable) y opcionalmente
CloudWatch Logs
|   |   |— CloudTrail Insights → detecta anomalías de API (picos de write
events)
|   |   |   |— EXAMEN: "quién hizo qué y cuándo" → siempre CloudTrail
|   |   |
|   |   |— CloudWatch
|   |   |   |— Metrics → métricas de servicios AWS (CPU, NetworkIn, etc.)
|   |   |   |— Logs → recibe logs de EC2, Lambda, CloudTrail, VPC Flow
Logs
|   |   |   |— Alarms → threshold → SNS → Lambda → auto-remediation
|   |   |   |— Dashboards → visualización operativa
|   |   |   |— EXAMEN: "monitorizar y alertar sobre métricas" → CloudWatch
|   |   |
|   |   |— AWS Config
|   |   |   |— QUÉ hace: registra el ESTADO de los recursos y sus CAMBIOS en
el tiempo
|   |   |   |   |— NO registra quién hizo la llamada API (eso es
CloudTrail)
|   |   |   |— Config Rules → evalúan si los recursos cumplen reglas
|   |   |   |   |— Managed: mfa-enabled-for-iam-console-access, s3-bucket-
public-read-prohibited
|   |   |   |   |— encrypted-volumes, rds-storage-encrypted, vpc-
flow-logs-enabled
|   |   |   |   |— Custom: Lambda evalúa tu propia lógica
|   |   |   |— Remediation → SSM Automation Documents para auto-remediar
|   |   |   |— EXAMEN: "compliance continua", "drift detection", "recurso en
estado X" → Config
|   |   |
|   |   |— VPC Flow Logs
|   |   |   |— Registra tráfico IP (ACCEPT/REJECT) a nivel de ENI/subnet/VPC
|   |   |   |— Entrega a CloudWatch Logs o S3
|   |   |   |— EXAMEN: "por qué falla la conexión" + "SG/NACL troubleshooting"
→ Flow Logs
|
|— 5. Protección en el Borde (ver diagrama edge-protection-layers.png)
|   |— WAF – Web Application Firewall
|   |   |— Opera en: CloudFront, ALB, API Gateway, AppSync
|   |   |— Protege contra: SQLi, XSS, OWASP Top 10, rate limiting, IP
blocking
|   |   |— Web ACLs → reglas → Allow/Block/Count
|   |   |— Managed Rules → grupos de reglas pre-configuradas (AWS +
Marketplace)
|   |   |— EXAMEN: "SQL injection", "XSS", "bloquear IPs específicas" →
WAF
|   |
|

```

```

|   |   |   | Shield
|   |   |   |   |   | Standard → GRATIS, siempre activo, protege L3/L4 (volumetric
DDoS)
|   |   |   |   |   |   | Incluido con CloudFront, Route 53, Global
Accelerator, ELB
|   |   |   |   |   |   |   | Advanced → ~$3.000/mes, protege L3/L4/L7, SRT (Shield Response
Team)
|   |   |   |   |   |   |   |   | reembolso de costes durante ataque, WAF sin cargo
adicional
|   |   |   |   |   |   |   |   | EXAMEN: "DDoS sofisticado", "soporte 24/7 para
DDoS" → Shield Advanced
|   |   |   |   |   |   |   |   |   | CloudFront como capa de seguridad
|   |   |   |   |   |   |   |   |   |   | HTTPS obligatorio (redirect HTTP→HTTPS)
|   |   |   |   |   |   |   |   |   |   | Geo-restriction → bloquear países específicos
|   |   |   |   |   |   |   |   |   |   | OAC (Origin Access Control) → S3 solo accesible desde
CloudFront
|   |   |   |   |   |   |   |   |   |   |   | Integra con WAF y Shield
|   |   |   |   |   |   |   |   |   |   |   | EXAMEN: "S3 solo via CloudFront" → OAC (antes OAI, deprecated)
|   |   |   |   |   |   |   |   |   |   |   |   | 6. Gobernanza Multi-Cuenta (ver diagrama organizations-identity-center-
control-tower.png)
|   |   |   |   |   |   |   |   |   |   |   |   |   | AWS Organizations
|   |   |   |   |   |   |   |   |   |   |   |   |   |   | Estructura
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Root → punto de partida, contiene todas las OUs
y cuentas
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Management Acct → cuenta raíz de la organización
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | EXAMEN: NUNCA usar para workloads; solo
governance
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Member Accounts → cuentas miembro (prod, dev, security,
sandbox...)
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | OUs (Org Units) → agrupaciones jerárquicas de cuentas
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | EXAMEN: SCPs heredadas de OU padres a
hijos
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | SCPs – Service Control Policies (CLAVE DEL EXAMEN)
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | QUÉ SON: límite máximo de permisos para cuentas miembro
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | NO otorgan permisos; solo limitan lo que las
policías IAM pueden hacer
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | La management account NUNCA está restringida por
SCPs
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Modo Allowlist (lista blanca)
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Por defecto Organizations aplica FullAWSAccess a la
root
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Tú eliminas FullAWSAccess y añades solo lo que quieres
permitir
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Más restrictivo, más seguro, mayor mantenimiento
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Modo Denylist (lista negra) ← MÁS COMÚN EN EXAMEN
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | FullAWSAccess aplicada (heredada de root)
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Añades SCPs que niegan acciones específicas
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |   | Ejemplos reales:

```

```

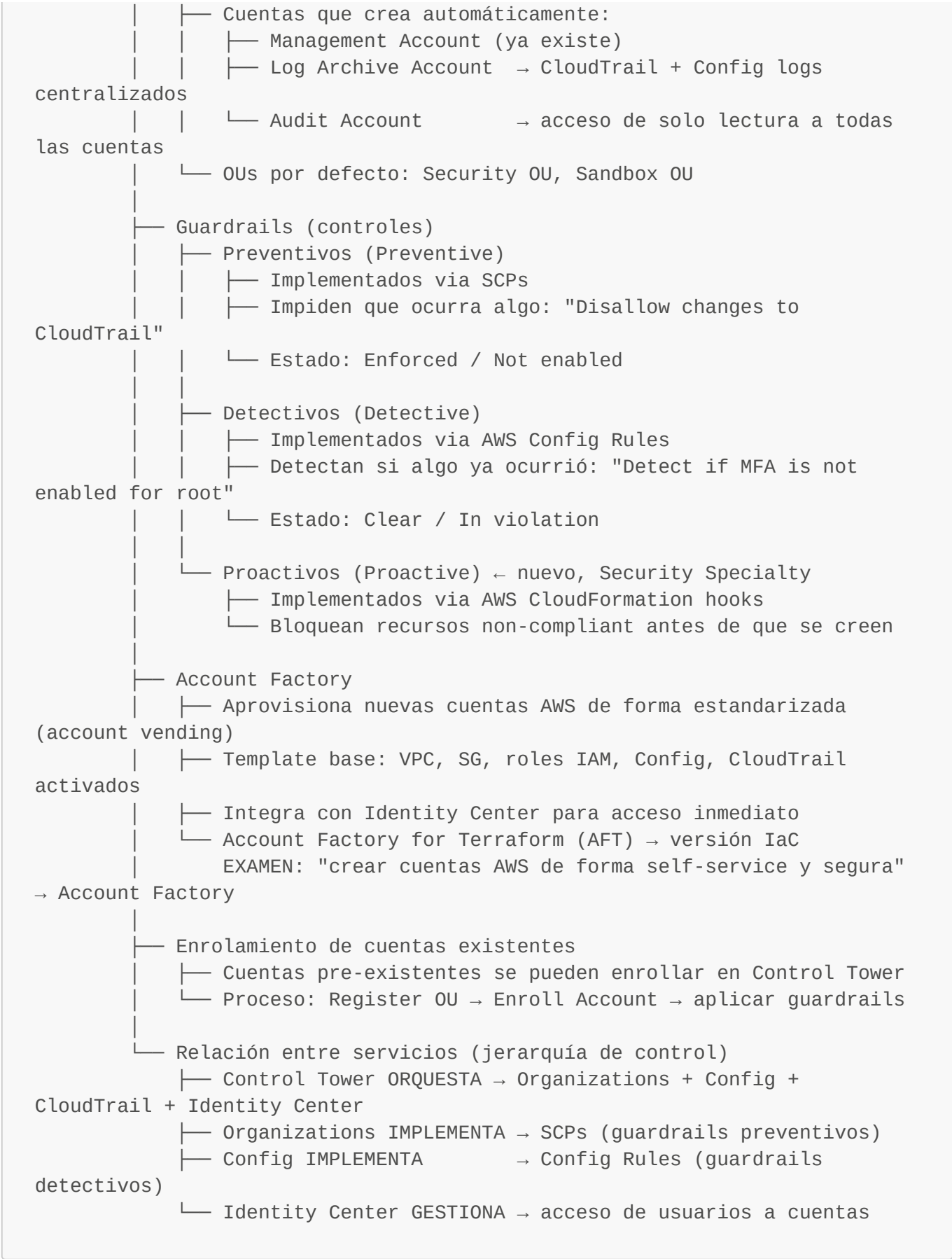
| | | | | DenyLeaveOrganization → cuentas no pueden salir
de la org
| | | | | DenyDisableCloudTrail → no se puede desactivar
auditoría
| | | | | DenyRegionsExceptEUWest1 → restricción de región
| | | | | DenyRootAccountUsage → root no puede hacer API
calls
| | | | | DenyCreateIAMUsers → solo roles, no users en
member accounts
| | | | | RequireIMDSv2 → fuerza metadatos
seguros en EC2
| | | | |
| | | | | Herencia: Root → OU padres → OUs hijas → Cuentas
| | | | | EXAMEN: una cuenta hereda TODAS las SCPs de todos sus OUs
ancestros
| | | | |
| | | | | La SCP más restrictiva en la cadena SIEMPRE gana
| | | | |
| | | | | SCPs NO afectan a:
| | | | | | Management Account (root account de la org)
| | | | | | Roles de servicio de AWS (service-linked roles)
| | | | | | Root user de cada cuenta miembro al gestionar recursos
| | | | |
| | | | | Consolidated Billing
| | | | | | Una sola factura para toda la organización
| | | | | | Volumen agregado → descuentos por uso combinado (S3, EC2,
etc.)
| | | | |
| | | | | Reserved Instances / Savings Plans se comparten entre
cuentas
| | | | |
| | | | | EXAMEN: RI de Cuenta A puede cubrir uso de Cuenta B si
Cuenta A no la usa
| | | | |
| | | | | Delegated Administration
| | | | | | Management Account puede delegar servicios a member
accounts
| | | | |
| | | | | Ejemplo: Security Account como admin delegado de Config,
GuardDuty, SecurityHub
| | | | |
| | | | | IAM Identity Center (antes AWS SSO)
| | | | | | QUÉ ES: solución centralizada de workforce identity para toda
la organización
| | | | |
| | | | | Un único punto de login para todos los usuarios → todas
las cuentas AWS
| | | | |
| | | | | EXAMEN: "usuarios corporativos acceden a múltiples
cuentas" → Identity Center
| | | | |
| | | | | Fuentes de identidad
| | | | | | Identity Center Directory → directorio propio
(usuarios/grupos en AWS)
| | | | |
| | | | | Active Directory (AWS Managed AD o AD Connector)
| | | | | External IdP via SAML 2.0 (Azure AD, Okta, Google
Workspace)
| | | | |
| | | | | + SCIM → sincronización automática de usuarios y grupos del
IdP
| | | | |

```

```

| | | Permission Sets
| | | | QUÉ SON: colección de políticas IAM que se convierten en un
IAM Role
| | | | cuando se asignan a un usuario/grupo en una cuenta
específica
| | | | Ejemplos: AdministratorAccess, ReadOnlyAccess,
CustomDevRole
| | | | FLUJO: Usuario IdP → Identity Center → AssumeRole en Cuenta
destino
| | | | con las políticas del Permission Set
| | | |
| | | | Assignments (asignaciones)
| | | | | Triada: [Usuario o Grupo] + [Permission Set] + [Cuenta AWS]
| | | | | Un desarrollador puede tener:
| | | | | | ReadOnly en Prod Account
| | | | | | AdminAccess en Dev Account
| | | | | Cambio centralizado: modificar el Permission Set → aplica a
todas las cuentas
| | | |
| | | | ABAC con Identity Center (Attribute-Based Access Control)
| | | | | Atributos del usuario (departamento, equipo, coste-center)
→ tags en la sesión
| | | | | Políticas IAM con condición aws:PrincipalTag → acceso
dinámico por atributo
| | | | | EXAMEN: "sin crear roles por cada equipo" + "atributos del
directorio" → ABAC
| | | |
| | | | MFA en Identity Center
| | | | | MFA por dispositivo (TOTP, WebAuthn/FIDO2)
| | | | | Configurable: nunca / solo cuando no está confiado /
siempre
| | | |
| | | | Diferencias clave para el examen
| | | | | Identity Center vs IAM Users: Identity Center para
workforce (personas)
| | | | | IAM Users para aplicaciones legacy o cuando no hay org
| | | | | Identity Center vs Cognito: Identity Center = workforce
(empleados)
| | | | | Cognito = customer identity (usuarios externos de tu app)
| | | | | Identity Center vs IAM Federation directa: Identity Center
es más fácil
| | | | | de gestionar a escala (multi-cuenta, SCIM sync, portal web
unificado)
| | | |
| | | | AWS Control Tower
| | | | | QUÉ ES: servicio que automatiza el despliegue de una Landing
Zone multi-cuenta
| | | | | segura y compliant sobre AWS Organizations
| | | | | EXAMEN: "setup automatizado de multi-cuenta seguro" →
Control Tower
| | | |
| | | | Landing Zone
| | | | | Conjunto pre-configurado de cuentas, OUs, guardrails y
redes base

```



B) Tabla de Referencia Rápida

Servicio	Cuándo usar	Señales en examen	Errores típicos
----------	-------------	-------------------	-----------------

Servicio	Cuándo usar	Señales en examen	Errores típicos
IAM Role	Apps en EC2/Lambda/ECS, Cross-account, Federation	"acceso a AWS desde app", "sin cred. estáticas"	Usar IAM User con clave en vez de role en EC2
IAM User	Solo para personas físicas o sistemas legacy que no soportan roles	"operador humano", "API key para CI/CD antiguo"	Poner claves en código o variables de entorno
STS AssumeRole	Acceso cross-account, escalado de privilegios temporal	"cuenta A accede a recursos de cuenta B"	Confundir con resource-based policy (S3 puede prescindir de AssumeRole)
Permission Boundary	Delegar creación de roles a devs sin riesgo de escalada	"devs crean roles pero no pueden darse más permisos que ellos mismos"	Crear que da permisos (solo limita el máximo)
SSM Session Manager	Acceso a EC2/ECS sin SSH, sin puerto 22	HIPAA, PCI-DSS, "sin bastion", "sin keys"	Usar EC2 Instance Connect (aún usa SSH port 22)
KMS CMK	Control de claves de cifrado, auditoría de uso, multi-servicio	"control del cliente sobre las claves", "auditar quién descifra"	Usar AWS Managed Key cuando piden control del cliente
Secrets Manager	Credenciales DB, API keys, rotación automática	"rotar automáticamente", "credenciales RDS sin hardcode"	Usar SSM Parameter Store sin rotación nativa para DB
SSM Param Store	Configuración de aplicación, parámetros no-rotativos, bajo coste	"parámetros de configuración", "presupuesto limitado"	Usar para secretos críticos que necesitan rotación
ACM	TLS en ALB, CloudFront, API Gateway, NLB	"certificado SSL/TLS gestionado", "auto-renovación"	Crear que se puede instalar el cert en EC2 directamente (no exportable)
CloudTrail	Auditoría de quién hizo qué API call	"auditoría", "quién borró", "quién accedió", "cuándo"	Confundir con Config (CloudTrail=quién, Config=qué estado)
AWS Config	Compliance continua, drift, estado de recursos	"¿está cifrado el EBS?", "¿S3 tiene MFA delete?", "non-compliant"	Confundir con CloudTrail (Config=estado, CloudTrail=API calls)
CloudWatch Alarms	Alertar sobre métricas (CPU, errores 5xx, throttle)	"notificar cuando CPU > 80%", "auto-scaling trigger"	Usar CloudTrail para métricas (CloudTrail no tiene métricas)

Servicio	Cuándo usar	Señales en examen	Errores típicos
VPC Flow Logs	Diagnóstico de conectividad de red	"tráfico rechazado", "SG o NACL bloqueando", "troubleshoot"	Confundir con CloudTrail (Flow Logs=tráfico IP, no API calls)
WAF	Protección L7 (HTTP/HTTPS) contra ataques de aplicación	"SQL injection", "XSS", "rate limiting", "bloquear bots"	Crear que WAF protege de DDoS volumétrico (eso es Shield)
Shield Standard	Siempre activo, gratis, protección básica DDoS	"protección DDoS básica incluida"	Crear que necesita configuración (es automático)
Shield Advanced	Protección avanzada DDoS + soporte SRT	"DDoS sofisticado", "necesito soporte AWS durante ataque"	Confundir con WAF (Shield=DDoS, WAF=aplicación L7)
CloudFront OAC	S3 privado accesible solo via CloudFront	"S3 no accesible directamente", "solo desde CDN"	Usar OAI (deprecated) en vez de OAC
S3 Bucket Policy	Control de acceso cross-account o desde VPC Endpoint	"solo acceso desde mi VPC", "permitir otra cuenta a mi bucket"	Usar ACLs (legacy) para control de acceso moderno
AWS Organizations	Gestionar múltiples cuentas AWS con factura única y SCPs	"múltiples cuentas", "factura consolidada", "política a nivel empresa"	Crear que SCPs otorgan permisos (solo limitan)
SCPs	Restricciones de seguridad que ninguna cuenta miembro puede saltarse	"impedir que devs borren CloudTrail", "restringir regiones", "política de toda la org"	Crear que afectan a la Management Account
IAM Identity Center	Login único para empleados en múltiples cuentas AWS	"SSO corporativo", "Azure AD con acceso a AWS", "empleados en múltiples cuentas"	Confundir con Cognito (Identity Center = workforce, Cognito = clientes)
Permission Sets	Definir qué puede hacer un empleado en una cuenta concreta	"rol de acceso estandarizado para todos los devs en prod"	Crear que son IAM Roles directos (son plantillas que generan roles)
Control Tower	Setup automatizado de Landing Zone multi-cuenta segura	"desplegar AWS para empresa desde cero", "multi-cuenta con guardrails", "account vending"	Crear que es solo para cuentas nuevas (puede enrollar existentes)

Servicio	Cuándo usar	Señales en examen	Errores típicos
Account Factory	Provisionar nuevas cuentas AWS de forma estandarizada	"self-service de cuentas", "nueva cuenta lista en minutos", "template de cuenta"	Crear cuentas manualmente en Organizations sin guardrails aplicados
Guardrails Preventivos	Bloquear acciones peligrosas a nivel organizacional	"impedir deshabilitar CloudTrail", "no permitir salir de la org"	Confundir con guardrails detectivos (preventivo=SCP=bloquea, detectivo=Config=detecta)
Guardrails Detectivos	Detectar configuraciones no conformes en cuentas miembro	"alertar si MFA no está activo", "detectar buckets públicos en toda la org"	Creer que bloquean (solo detectan, no impiden)

C) Ejemplos End-to-End con Decisiones Justificadas

Ejemplo 1 — Fintech: API de pagos PCI-DSS en eu-west-1

Escenario: Startup fintech con API REST de pagos. Arquitectura: React SPA → API Gateway → Lambda → Aurora MySQL. Requisitos: PCI-DSS, cifrado end-to-end, auditoría completa, sin credenciales hardcoded.

Arquitectura de Seguridad

```
Internet → Shield Standard (automático)
          → CloudFront (HTTPS, TLS 1.2+, Geo-restriction no-EU)
          → WAF (SQLi rules, rate limit 1000 rps/IP)
          → API Gateway (HTTPS, ACM cert)
          → Lambda (IAM execution role)
          → Aurora (KMS CMK, VPC private subnet, SG: solo Lambda)
```

Decisiones y Justificaciones

Componente	Decisión	Por qué
Credenciales Aurora	Secrets Manager con rotación 30 días	Lambda usa role → <code>boto3.client('secretsmanager').get_secret_value()</code> . Sin creds en env vars ni código. PCI req 8.6
Cifrado DB	KMS CMK <code>alias/fintech-aurora-prod</code>	Control de quién descifra, logs en CloudTrail, rotación anual

Componente	Decisión	Por qué
Auditoría API	CloudTrail (Management + Data Events en S3)	Evidencia de quién llamó a qué Lambda, qué modificó en Aurora vía RDS API
Compliance continua	Config rule <code>rds-storage-encrypted</code> + <code>lambda-function-public-access-prohibited</code>	Alerta si alguien crea RDS sin cifrado o Lambda expuesta
Acceso DevOps a Lambda/Aurora	IAM Role <code>fintech-devops</code> con Permission Boundary	No pueden crear roles con más permisos de los suyos propios
TLS	ACM cert en API Gateway + CloudFront	Auto-renovación, sin gestión manual de certs
DDoS L7	WAF con AWS Managed Rules (Core rule set)	Rate limiting + SQLi + XSS cubiertos

Política de ejemplo — Mínimo privilegio Lambda

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["secretsmanager:GetSecretValue"],
      "Resource": "arn:aws:secretsmanager:eu-west-1:123456789:secret:fintech/aurora/prod-*"
    },
    {
      "Effect": "Allow",
      "Action": ["kms:Decrypt"],
      "Resource": "arn:aws:kms:eu-west-1:123456789:key/mrk-abc123",
      "Condition": {
        "StringEquals": {"kms:ViaService": "secretsmanager.eu-west-1.amazonaws.com"}
      }
    }
  ]
}
```

Señal examen: kms:ViaService → Lambda solo puede descifrar VÍA Secrets Manager, no directamente.

Ejemplo 2 — E-Commerce: Plataforma multi-tier con equipo de 50 devs

Escenario: E-commerce B2C. ALB → EC2 ASG (app) → RDS Aurora + ElastiCache. Equipo de 50 devs con acceso a staging, 5 ops con acceso a producción. Presupuesto ajustado → optimizar costes de seguridad.

Arquitectura de Seguridad

Internet → Shield Standard (gratis)
→ CloudFront (OAC para S3 assets, HTTPS)
→ ALB (ACM cert, WAF basic rules)
→ EC2 ASG con IAM Instance Profile
→ Aurora (KMS AWS Managed Key, SG: from app-sg only)
→ ElastiCache Redis (encryption in-transit TLS, at-rest KMS)

Decisiones por restricción de presupuesto

Componente	Decisión	Alternativa rechazada	Razón
KMS	AWS Managed Key (gratis)	CMK (\$1/key/mes)	No necesitan control granular del key; AWS la gestiona
Secretos	SSM Parameter Store SecureString (\$0)	Secrets Manager (\$0.40/mes)	No hay rotación automática de DB — se rota manualmente cada trimestre
DDoS	Shield Standard (gratis)	Shield Advanced (\$3.000/mes)	No son objetivo de DDoS sofisticado
Auditoría	CloudTrail 1 trail gratuito → S3	CloudTrail Insights (+coste)	Presupuesto limitado; revisar logs manualmente si hay incidente
Acceso EC2	SSM Session Manager (gratis)	Bastion EC2 (\$)	Sin coste adicional, sin SSH key management, auditado

Acceso multi-equipo con roles separados

IAM Group "devs-staging"
└─ Role "ecommerce-dev" → acceso solo a staging (Condition: aws:RequestedRegion = eu-west-1, tag:Env = staging)

IAM Group "ops-prod"
└─ Role "ecommerce-ops" → acceso prod (MFA requerido:

```
aws:MultiFactorAuthPresent = true)
```

```
IAM Role "ecommerce-ec2-profile" (instance profile)
```

```
└─ Solo ssm:*, cloudwatch:PutMetricData, secretsmanager:GetSecretValue
```

Config Rules activadas (coste mínimo)

- | | |
|--------------------------------------|-----------------------------------|
| - encrypted-volumes | → EBS sin cifrar = NON_COMPLIANT |
| - rds-storage-encrypted | → Aurora sin KMS = NON_COMPLIANT |
| - s3-bucket-public-read-prohibited | → bucket público = NON_COMPLIANT |
| - mfa-enabled-for-iam-console-access | → user sin MFA = NON_COMPLIANT |
| - iam-no-inline-policy-check | → inline policies = NON_COMPLIANT |

Ejemplo 3 — Healthcare: Sistema EHR con HIPAA en arquitectura multi-cuenta

Escenario: Hospital con sistema EHR (Electronic Health Records). Requisitos HIPAA: datos de pacientes cifrados, auditoría de todos los accesos, mínima exposición de superficie. Arquitectura multi-cuenta: Management Account → Security Account → Prod Account.

Arquitectura Multi-cuenta

Management Account (Organizations root)

- └─ SCP: DenyRegionsExceptEUWest1 (restringe a eu-west-1)
- └─ SCP: DenyDisableCloudTrail
- └─ SCP: DenyRootAccountActions

Security Account (centralizado)

- └─ CloudTrail (Organization Trail → todos los eventos de todas las cuentas)
- └─ AWS Config Aggregator (vista unificada de compliance)
- └─ Security Hub (agregación de hallazgos: Config + GuardDuty + Inspector)
- └─ S3 Bucket (CloudTrail logs de toda la org, Object Lock, KMS CMK)

Prod Account (EHR)

- └─ VPC (3 tiers: ALB public, App private, DB private)
- └─ ALB → NLB → EC2 (IAM Role, SSM Agent)
- └─ ↓
- └─ Aurora MySQL (KMS CMK dedicado `alias/ehr-aurora-phi`)
- └─ S3 (documentos clínicos, SSE-KMS, Block Public Access, Object Lock WORM)
- └─ Secrets Manager (credenciales Aurora, rotación 7 días, KMS CMK)

Decisiones HIPAA-específicas

Requisito HIPAA	Solución AWS	Por qué esta y no otra
Cifrado PHI at rest	KMS CMK (Customer Managed)	Audit trail de quién descifra, evidencia para auditor HIPAA (BAA). AWS Managed Key no permite controlar quién accede al key
Cifrado PHI in transit	TLS 1.2+ (ACM) + NLB TLS pass-through	Datos de pacientes no pueden viajar en texto plano en ningún segmento
Acceso mínimo	IAM con Permission Boundaries + Roles separados por función	Médicos: solo leer su paciente. Admin: solo metadatos. Sin acceso cruzado
Auditoría de acceso	CloudTrail Data Events en S3 (GetObject de historiales) + KMS DecryptEvents	Saber quién abrió qué historial, cuándo. HIPAA audit control §164.312(b)
Acceso sistemas	SSM Session Manager + No SSH + SG sin 22	Sin keys que rotar, sin bastion comprometible, auditoría completa en CloudTrail
Inmutabilidad de logs	S3 Object Lock (Compliance Mode)	CloudTrail logs no eliminables ni modificables — evidencia forense
Detección de accesos anómalos	CloudWatch Metric Filter → Alarm → SNS	ej: <code>filter pattern: "UnauthorizedAccess"</code> → <code>alarm</code> → <code>security team</code>
No acceso directo S3	CloudFront OAC + S3 Block Public Access	Documentos clínicos solo accesibles via app autenticada, nunca via URL pública

Trust Policy del rol de producción (cross-account desde Security Account)

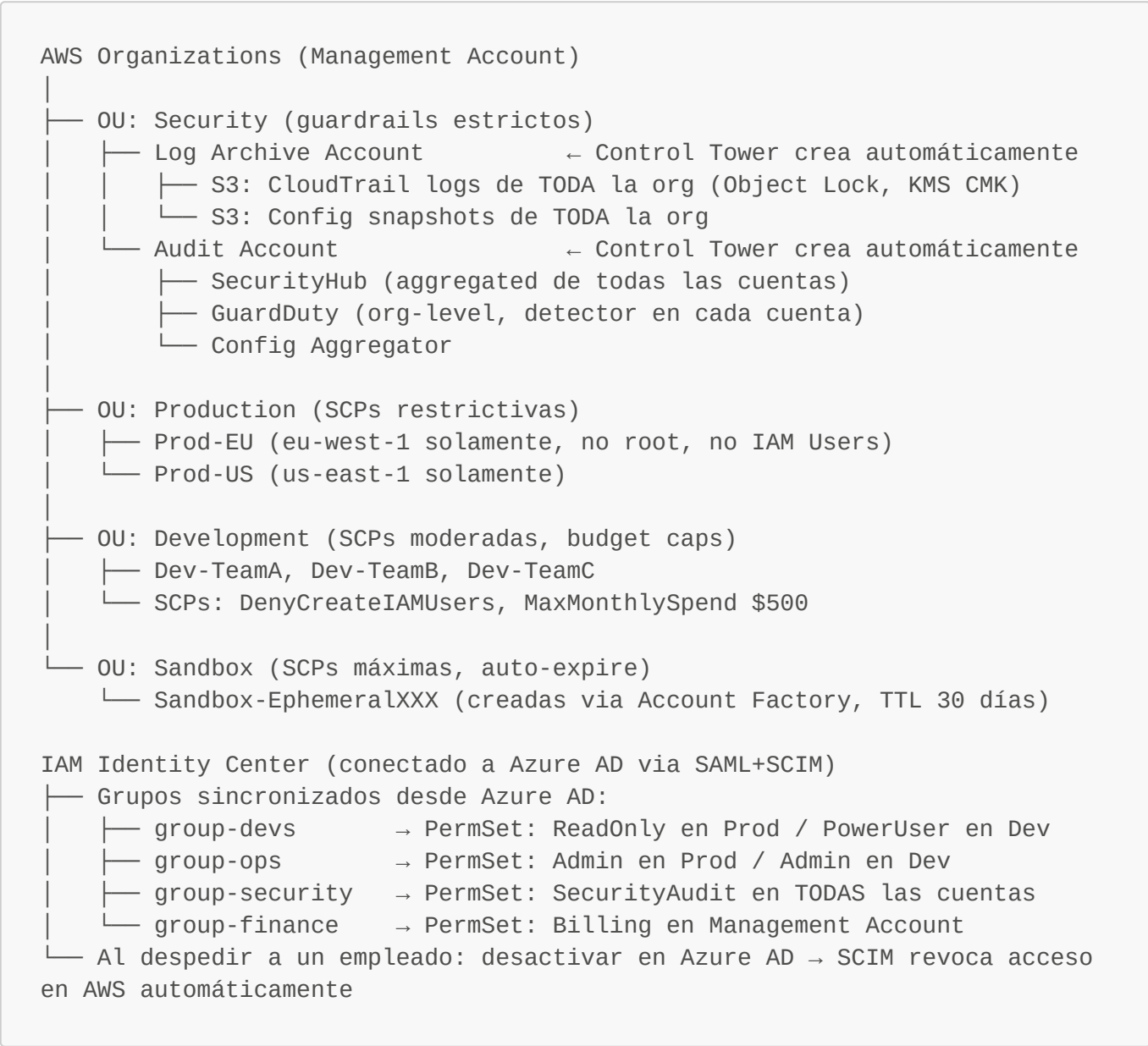
```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Principal": {
      "AWS": "arn:aws:iam::SECURITY_ACCOUNT_ID:role/security-auditor"
    },
    "Action": "sts:AssumeRole",
    "Condition": {
      "Bool": {"aws:MultiFactorAuthPresent": "true"},
      "StringEquals": {"sts:ExternalId": "ehr-security-audit-2024"}
    }
  }]
}
```

ExternalId previene el "confused deputy problem" — un tercero que conoce el ARN del rol no puede asumirlo sin el ExternalId secreto.

Ejemplo 4 — Empresa con 20 cuentas AWS: migración a modelo de gobernanza centralizado

Escenario: Empresa de 500 personas con 20 cuentas AWS creadas orgánicamente a lo largo de 5 años (sin estructura). Cada equipo gestiona su cuenta de forma independiente. Problemas actuales: (1) no hay visibilidad centralizada de gastos, (2) algunos equipos han desactivado CloudTrail, (3) los accesos se gestionan con IAM Users en cada cuenta (500 usuarios × 20 cuentas = 10.000 pares de credenciales), (4) cuando alguien se va de la empresa hay que revocar acceso en 20 cuentas manualmente.

Arquitectura objetivo (después de la migración)



Decisiones de migración y justificaciones

Problema	Solución	Implementación
CloudTrail desactivado en algunas cuentas	SCP <code>DenyDisableCloudTrail</code> + Organization Trail	SCP preventiva: ninguna cuenta puede desactivar trail. Organization Trail crea trail en todas las cuentas automáticamente

Problema	Solución	Implementación
10.000 pares de credenciales IAM	IAM Identity Center + SCIM desde Azure AD	Eliminar todos los IAM Users en cuentas miembro. Identity Center como único punto de acceso
Offboarding manual en 20 cuentas	SCIM sync desde Azure AD	Desactivar usuario en Azure AD → SCIM sync → acceso revocado en todas las cuentas AWS en < 2 min
Sin visibilidad de gastos	Consolidated Billing + AWS Budgets en cada OU	Factura única + alertas de presupuesto por OU y por cuenta
Nuevas cuentas sin estructura	Control Tower Account Factory	Template estandarizado: VPC, CloudTrail, Config, Identity Center access automáticamente configurados
Auditoría dispersa	Config Aggregator + Security Hub en Audit Account	Vista unificada de compliance y findings de TODAS las cuentas desde un único panel

SCPs implementadas por OU

```
// SCP: DenyCreateIAMUsers (aplicada a Production OU y Development OU)
// Obliga a usar Identity Center; ningún equipo puede crear IAM Users
{
  "Effect": "Deny",
  "Action": ["iam:CreateUser", "iam:CreateAccessKey"],
  "Resource": "*",
  "Condition": {
    "StringNotEquals": {
      "aws:PrincipalARN": "arn:aws:iam::*:role/AWSControlTowerExecution"
    }
  }
}

// SCP: DenyRegionsExceptApproved (aplicada a Prod OU)
// Solo eu-west-1 y us-east-1 permitidos en producción
{
  "Effect": "Deny",
  "Action": "*",
  "Resource": "*",
  "Condition": {
    "StringNotEquals": {
      "aws:RequestedRegion": ["eu-west-1", "us-east-1"]
    },
    "StringNotLike": {
      "aws:PrincipalARN": "arn:aws:iam::*:role/AWSControlTower*"
    }
  }
}
```

1. Empleado entra a `portal.sso.amazonaws.com`
2. Redirigido a Azure AD (SAML) → autenticación corporativa + MFA
3. Identity Center recibe SAML assertion con grupos del empleado
4. Identity Center muestra las cuentas AWS disponibles para ese empleado
5. Empleado selecciona "Prod-EU → PowerUser"
6. Identity Center llama a `STS:AssumeRoleWithWebIdentity`
7. Se generan credenciales temporales (max 12h) del rol PowerUser en Prod-EU
8. El empleado usa esas credenciales (via consola, CLI o SDK)

Disparadores directos

/

Si el escenario menciona...	Respuesta
"S3 solo desde CloudFront", "CDN con origen privado"	CloudFront + OAC
"cross-account access", "cuenta A accede a cuenta B"	STS AssumeRole
"confused deputy", "tercero asume mi rol"	ExternalId en Trust Policy
"devs no pueden darse más permisos de los que tienen"	Permission Boundary
"solo acceso desde mi VPC a S3/DynamoDB"	VPC Gateway Endpoint
"usuarios corporativos en múltiples cuentas AWS", "SSO para empleados"	IAM Identity Center
"sincronizar usuarios de Azure AD / Okta con AWS"	Identity Center + SCIM
"revocar acceso en todas las cuentas cuando alguien se va"	Identity Center + SCIM (un solo punto)
"empleados pueden acceder a Dev como admin y a Prod como readonly"	Permission Sets por cuenta
"setup de nueva empresa en AWS con seguridad desde el día 1"	Control Tower (Landing Zone)
"crear nueva cuenta AWS de forma estandarizada y autoservicio"	Account Factory
"impedir que ninguna cuenta pueda desactivar CloudTrail"	SCP (preventivo) via Organizations
"detectar si alguna cuenta tiene MFA desactivado en root"	Control Tower guardrail detectivo (Config Rule)
"factura única para 20 cuentas AWS", "descuentos de volumen agregados"	Organizations — Consolidated Billing
"RI de una cuenta cubre uso de otra cuenta"	Organizations — RI Sharing
"política que se aplica a TODA la organización sin excepción"	SCP (Organizations)
"aplicación web cuyos usuarios son clientes externos"	Amazon Cognito (≠ Identity Center)

Trampas / Distractores Típicos

Distractor	Trampa	Respuesta correcta
"CloudTrail para ver si S3 está cifrado"	CloudTrail registra quién cifró, no el estado actual	AWS Config para estado de recursos
"Config para saber quién borró la instancia"	Config registra cambios de estado, no quién los hizo	CloudTrail para identidad + acción
"WAF para protección DDoS"	WAF filtra L7, no ataques volumétricos L3/L4	Shield para DDoS, WAF para L7

Distractor	Trampa	Respuesta correcta
"SG en lugar de WAF"	SGs son stateful L3/L4 (IP/puerto)	WAF para SQLi/XSS (L7, payload HTTP)
"IAM User con clave para Lambda/EC2"	Clave estática en entorno app = riesgo	IAM Role (instance profile, execution role)
"KMS para rotar secretos DB"	KMS gestiona claves criptográficas, no secretos	Secrets Manager para credenciales con rotación
"Secrets Manager para parámetros de config"	Secrets Manager cuesta \$0.40/mes por secreto	SSM Parameter Store para config no-sensible
"EC2 Instance Connect = sin SSH"	Instance Connect aún usa SSH (puerto 22 debe estar abierto)	SSM Session Manager para 0 puertos
"OAI para nuevo CloudFront + S3"	OAI está deprecated desde 2022	OAC (Origin Access Control) es el actual
"Inline policy = más segura porque solo aplica a esa entidad"	Inline policies no se pueden auditar/reutilizar fácilmente	Managed policies (reutilizables, versionadas)
"Permission Boundary otorga permisos adicionales"	Boundaries LIMITAN, no OTORGAN	Sigue necesitando una identity-based policy que otorgue
"CloudWatch para auditar API calls"	CW no registra API calls de control plane	CloudTrail para API calls
"ACM cert instalado directamente en EC2"	ACM certs no son exportables	Cert de CA privada o externo importado en ACM
"SCP otorga permisos a cuentas miembro"	SCP NUNCA otorga → solo limita el máximo posible	IAM policies dentro de la cuenta otorgan; SCP limita el techo
"SCP restringe a la Management Account"	Management Account NUNCA está sujeta a SCPs	SCPs solo afectan a member accounts
"Identity Center = Cognito"	Identity Center = workforce (empleados internos)	Cognito = customer identity (usuarios de tu app externa)
"Permission Set = IAM Role"	Permission Set es una plantilla; al asignarse CREA un IAM Role en la cuenta destino	Son diferentes: Permission Set es el template, el Role es la instancia
"Control Tower solo para cuentas nuevas"	Control Tower puede enrollar cuentas existentes	Proceso: Register OU → Enroll Account
"guardrail detective bloquea el recurso"	Detectivos DETECTAN pero no bloquean; los preventivos (SCPs) bloquean	Guardrail detective = Config Rule que marca NON_COMPLIANT, pero no impide

Distractor	Trampa	Respuesta correcta
"SCIM sincroniza políticas IAM"	SCIM solo sincroniza usuarios y grupos (identidades)	Las políticas se gestionan via Permission Sets, no via SCIM
"Identity Center reemplaza completamente a IAM"	IAM sigue siendo necesario para service roles, instance profiles, etc.	Identity Center gestiona acceso humano; IAM gestiona acceso de servicios/apps
"Organizations Consolidated Billing requiere control total de las cuentas"	Puedes tener Consolidated Billing sin forzar SCPs (si no quieres)	La facturación consolidada es independiente de los guardrails

Referencias Rápidas — Servicios de Seguridad

Identidad:

IAM Users · IAM Roles · IAM Groups · STS · Cognito (clientes) · Identity Center (workforce)

Políticas:

Identity-based · Resource-based · Permission Boundary · SCP (Organizations) · Session Policies

Cifrado:

KMS (CMK) · ACM (TLS) · CloudHSM (dedicated hardware)

Secretos:

Secrets Manager (rotación automática) · SSM Parameter Store (config/parámetros)

Acceso EC2:

SSM Session Manager · Run Command · EC2 Instance Connect

Logging:

CloudTrail · CloudWatch Logs · VPC Flow Logs · S3 Access Logs

Compliance:

AWS Config · Security Hub · GuardDuty · Inspector · Macie

Borde:

WAF · Shield Standard/Advanced · CloudFront (OAC) · Firewall Manager

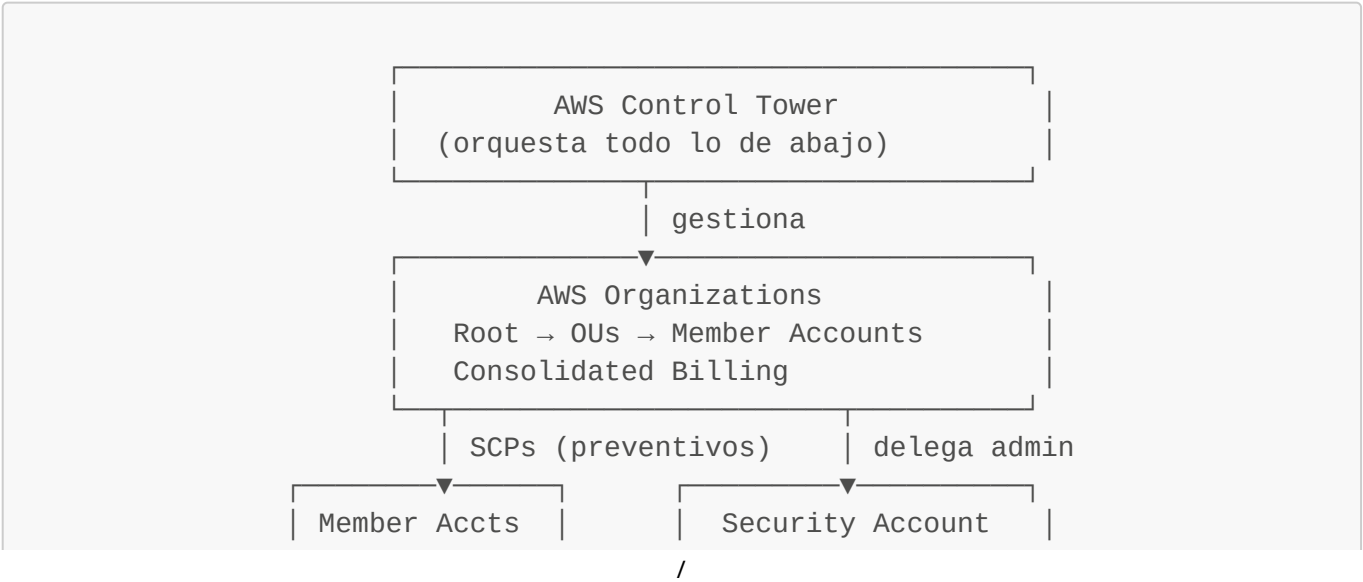
Gobernanza:

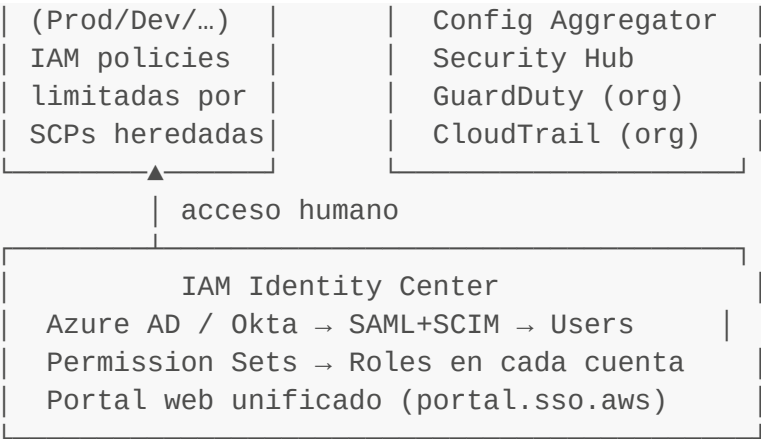
AWS Organizations · SCPs · IAM Identity Center · Control Tower · Account Factory

Multi-cuenta:

Management Account · OUs · Log Archive Account · Audit Account · SCIM sync · Permission Sets

E) Mapa Mental: Gobernanza Multi-Cuenta — Relaciones Clave





FLUJO DE EVALUACIÓN DE PERMISOS EN MULTI-CUENTA:

- | | |
|---|-------------------------|
| 1. ¿Hay Deny explícito en SCP de algún OU ancestro? | → DENY (fin) |
| 2. ¿La SCP permite la acción? (FullAWSAccess o Allowlist) | → continuar / DENY |
| 3. ¿Hay Permission Boundary en el IAM principal? | → limita el máximo |
| 4. ¿La Identity-based policy permite la acción? | → continuar / DENY |
| 5. ¿Hay Resource-based policy? | → puede Allow adicional |
| 6. Default implícito | → DENY |